
Segurança na Web

Professor: Alexandre Teixeira

Vivemos na era da informação. Com isso, a informação assume um valor como qualquer ativo físico. Como um ativo, e para ser considerada segura, a informação precisa ser protegida contra ataques, acessos não autorizados e alterações não autorizadas; também deve estar disponível para uma entidade autorizada quando necessário (Forouzan, 2013).

Uma vez que conectamos as máquinas em rede, os dados gravados nelas estão em risco potencial de acesso indevido. Isso acontece porque os dados que fluem numa rede podem ser espionados, copiados e alterados por terceiros, isso faz com que informação sensível possa ser obtida ilicitamente através da rede;

A Figura 01 mostra quem poderia acessar alguma informação e com qual objetivo. A Figura 02 mostra a quantidade de ataques reportados ao CERT.br desde 1999.

Adversário	Objetivo
Estudante	Divertir-se bisbilhotando as mensagens de correio eletrônico de outras pessoas
Cracker	Testar o sistema de segurança de alguém; roubar dados
Representante de vendas	Tentar representar toda a Europa e não apenas Andorra
Executivo	Descobrir a estratégia de marketing do concorrente
Ex-funcionário	Vingar-se por ter sido demitido
Contador	Desviar dinheiro de uma empresa
Corretor de valores	Negar uma promessa feita a um cliente por meio de uma mensagem de correio eletrônico
Vigarista	Roubar números de cartão de crédito e vendê-los
Espião	Descobrir segredos militares ou industriais de um inimigo
Terrorista	Roubar segredos de armas bacteriológicas

Figura 01 – Acesso à Informação

Fonte: Tanenbaum, 2011.

Notificações de incidentes recebidas pelo CERT.br 2014 a Janeiro de 2025

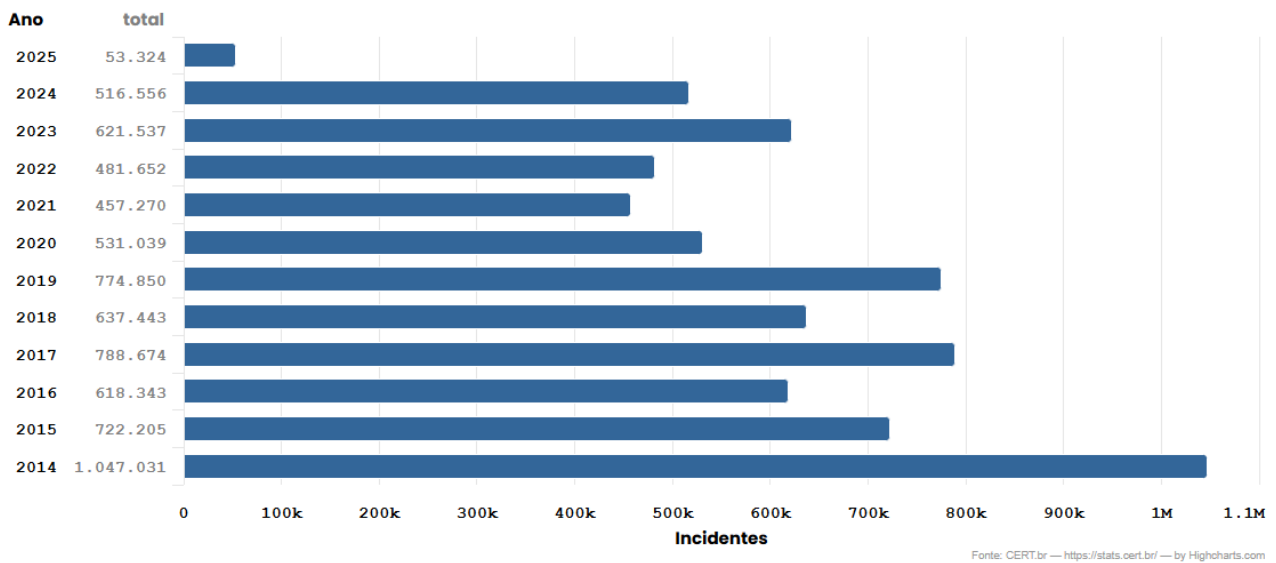


Figura 02 – Incidentes Reportados ao CERT.br.

Fonte: CERT.br, 2025.

Os problemas com a segurança de rede ocorrem quando não é possível oferecer os seguintes serviços de segurança:

- Sigilo ou confidencialidade.
- Autenticação.
- Não Repúdio.
- Integridade.
- Disponibilidade.

O **Sigilo ou confidencialidade** é a proteção da informação contra ataques de acessos não autorizados. Precisa ser aplicada tanto no armazenamento quando na transmissão das informações.

A **autenticação** é a garantia de que tanto um transmissor quanto um receptor estejam identificados.

O **não repúdio** significa que um emissor não deve ser capaz de rejeitar uma mensagem que ele, de fato, enviou.

A **Integridade** significa que os dados devem chegar ao receptor exatamente da forma que foram enviados, sem nenhuma alteração durante a transmissão, seja de forma acidental ou mal-intencionada.

A **disponibilidade** é a garantia de que os dados, serviços ou a infraestrutura estarão funcionando, estarão acessíveis e estarão disponíveis aos usuários autorizados a utilizá-los.

Os ataques contra os serviços de segurança podem ser classificados em **ataques passivos** e **ataques ativos**.

Nos **ataques passivos** ocorre a espionagem e monitoramento da transmissão. O invasor pode obter o conteúdo da mensagem que está sendo transmitida ou pode fazer a análise de tráfego (Figura 03) procurando informações. Trata-se de conhecer a natureza e a origem da transmissão.

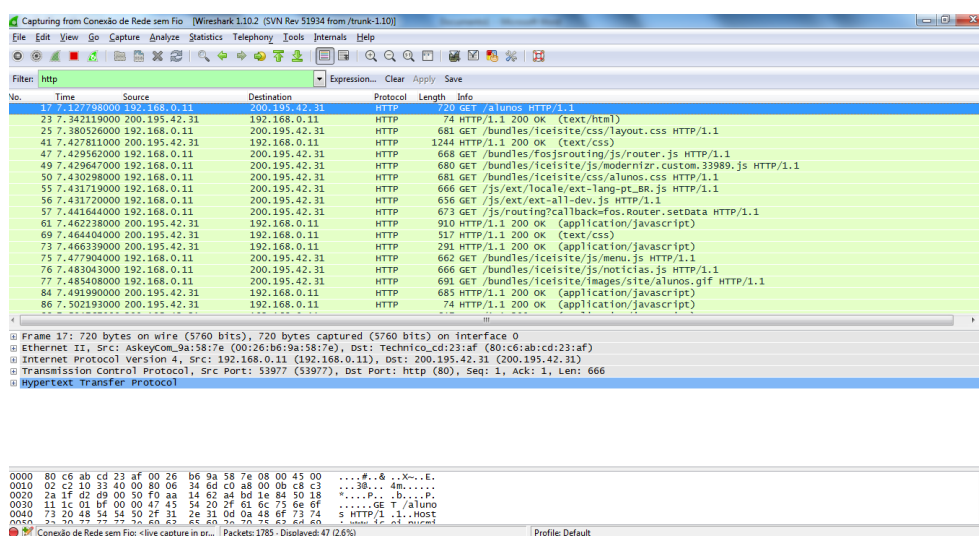


Figura 03 – Software de Captura de Pacotes

Os ataques passivos são difíceis de serem percebidos pelo administrador de redes, já que não alteram o conteúdo dos dados. A ênfase deve ser na prevenção e não na detecção destes ataques.

Os **Ataques Ativos** envolvem alguma modificação dos dados ou criação de dados falsos e possuem quatro subdivisões:

A **Modificação** ocorre quando há a alteração do conteúdo, da ordem ou atraso de alguma parte da mensagem.

A **Falsificação** é quando uma entidade finge ser outra.

A **Repetição** é quando envolve a captura passiva de alguma unidade de dados e a sua subsequente retransmissão para produzir um efeito não autorizado.

A **Negação de serviço** acontece quando os serviços de comunicação que dão acesso às informações de uma corporação são interrompidos por um ataque planejado por alguém mal intencionado.

Ao contrário dos ataques passivos, estes são fáceis de perceber, mas podem ser desastrosos em sua maioria. A ênfase deve ser na detecção e na recuperação após um ataque.

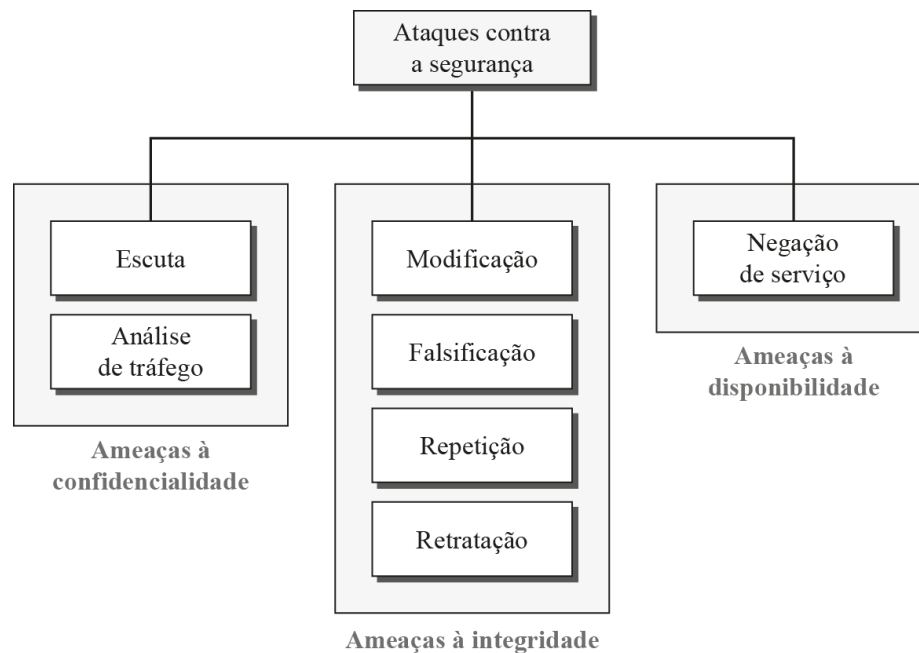


Figura 04 – Ataques Contra a Segurança.

Fonte: Forouzan, Mosharraf, 2013.

Trabalhamos com o conceito de camadas em redes de computadores. Assim, a segurança de redes pode ser implementada em todas as camadas. Com exceção da camada física, toda a segurança se baseia em princípios criptográficos.

A seguir têm-se alguns exemplos de segurança nas camadas.

Camada física:

- Proteção dos cabos para impedir o acesso a estes.
- Monitoramento de conexões físicas através de sensores.
- Sensor de presença.
- Uso de sala cofre.

Camada de enlace:

- Criptografia dos quadros durante a transmissão.
- Bloqueio de conexão a equipamentos por endereço MAC.
- Criação de VLANs segmentando a rede.

Camada de rede:

- Bloqueio de acesso por endereço de rede.
- Filtro de pacotes.
- IPSec.

Camada de transporte:

- Bloqueio de portas.
- Criptografia processo a processo.

Camada de Aplicação:

- Autenticação do usuário.

Criptografia.

Conforme informado anteriormente, com exceção da camada física, a segurança de rede é implementada nas camadas de rede com o uso da criptografia. Criptografia, ou “Escrita secreta” é a transformação matemática de uma mensagem de forma a torná-la ininteligível àquele que não possa operar uma transformação reversa a fim de obter a mensagem original. (Tanenbaum, 2011)

Vamos definir alguns termos referentes à criptografia (Forouzan, 2008).

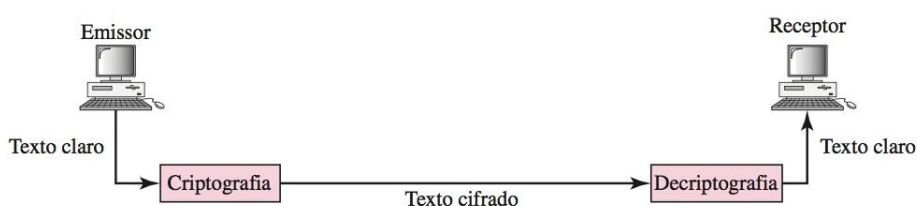


Figura 05 – Criptografia.

Fonte: Forouzan, 2008.

Texto Claro e Texto Cifrado. A mensagem original, antes de ser transformada, é chamada de texto claro. Depois de transformada, ela é denominada simplesmente texto cifrado. Um algoritmo de criptografia transforma o texto claro em texto cifrado; um algoritmo de decifração transforma o texto cifrado de volta para texto claro. O emissor usa um algoritmo de criptografia e o receptor utiliza um algoritmo de decifração.

Cifra. Chamamos cifras os algoritmos de criptografia e decifração. O termo também é usado para se referir a diferentes categorias de algoritmos em criptografia.

Chave. A Chave é um número (ou conjunto de números) sobre o qual a cifra, assim como um algoritmo, opera. Para criptografar uma mensagem, precisamos de um algoritmo de criptografia, uma chave criptográfica e o texto claro. Esses elementos criam o texto cifrado. Para decifrar uma mensagem, precisamos de um algoritmo de decifração, uma chave decifográfica e o texto cifrado. Estes revelam o texto claro original.

Assume-se que o intruso ou atacante seja capaz de interceptar e copiar o texto cifrado com precisão. No entanto, se o intruso não conhece a chave de criptografia ele não tem como converter o texto cifrado em texto claro (ou texto plano).

Os algoritmos de criptografia podem ser divididos em Algoritmos de Chave Secreta (ou Simétrica), Algoritmos de Chave Pública (ou Assimétrica) e Funções de Hash.

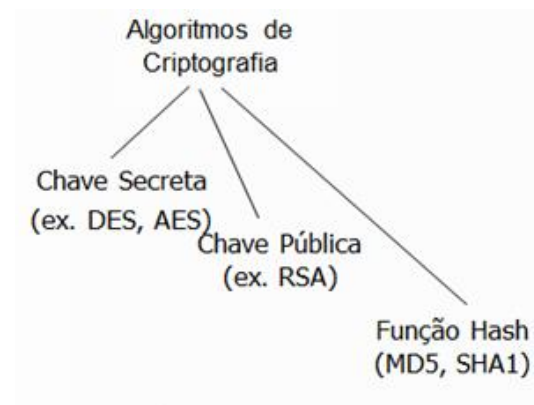


Figura 06 – Algoritmos de Criptografia

Fonte: Tanenbaum, 2011.

Algoritmos de chave Secreta (ou simétrica)

Algoritmos de chave simétrica (ou cifra simétrica) utilizam a mesma chave para cifrar(codificar) e decifrar (decodificar) a mensagem. Eles são chamados também algoritmos de chave secreta.

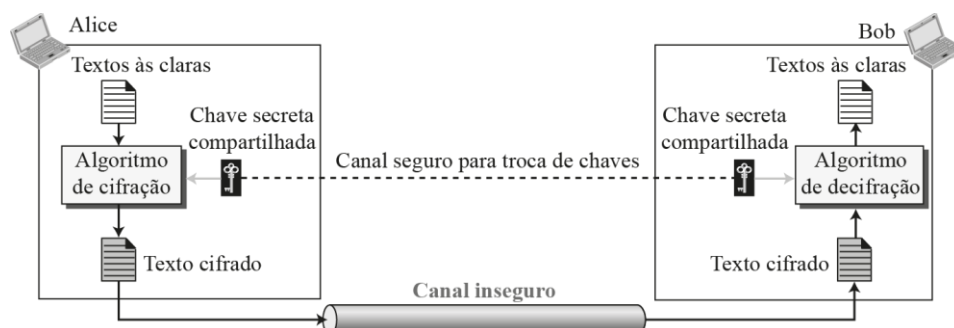


Figura 07 – Criptografia com chave simétrica.

Fonte: Forouzan, Mosharraf, 2013.

O principal problema dos algoritmos simétricos é que o transmissor e o receptor devem conhecer a chave antes do início da transmissão, uma vez que não é tão fácil fazer com que somente as duas partes conheçam a chave de cifração/decifração.

DES – Data Encryption Standard

O DES, já obsoleto, foi o algoritmo de criptografia que predominou de 1977 até 1998. No DES, um texto simples com blocos de 64 bits é criptografado produzindo blocos de 64 bits de texto cifrado, na decifração os blocos de 64 bits cifrados são convertidos em blocos de 64 bits de texto simples. O algoritmo possui uma chave de 56 bits que é usada tanto para cifrar quanto para decifrar o texto. Ele opera com 19 estágios distintos, com uma permutação inicial, uma permutação final e 16 rodadas intermediárias. Ele foi quebrado em um ataque de força bruta que durou 96 dias utilizando 70000 máquinas na Internet.

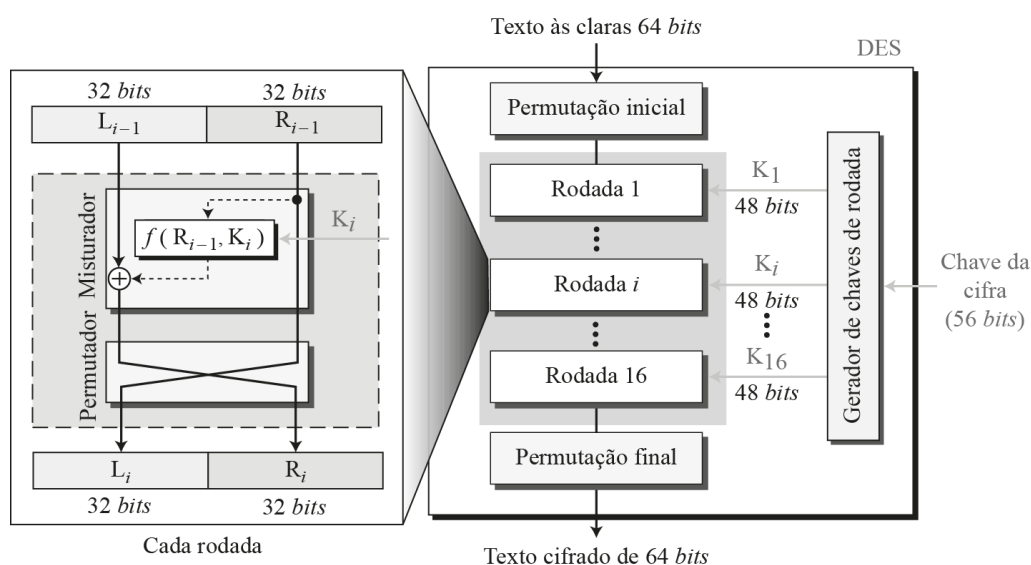


Figura 08 – Funcionamento do DES.

Fonte: Forouzan, Mosharraf, 2013.

AES – Advanced Encryption Standard

O AES é um algoritmo de criptografia simétrica fornecida pelo NIST (National Institute of Standards and Technology), através de um concurso, em 1997, com as seguintes regras:

- O algoritmo teria de ser uma cifra de bloco simétrica.
- Todo o projeto teria de ser público.
- Deveriam ser admitidos tamanhos de chaves iguais a 128, 192 e 256 bits.
- Teriam de ser possíveis implementações em hardware e software.

Ao final do concurso foi escolhido o algoritmo Rijndael (Joan Daemen e Vincent Rijmen) para ser o padrão de criptografia a partir de 2001. A operação do AES (Rijndael) trabalha com 10 rodadas em que cada rodada executa uma função de substituição de bytes, deslocamento de linhas, mistura de colunas e adição de chave da rodada.

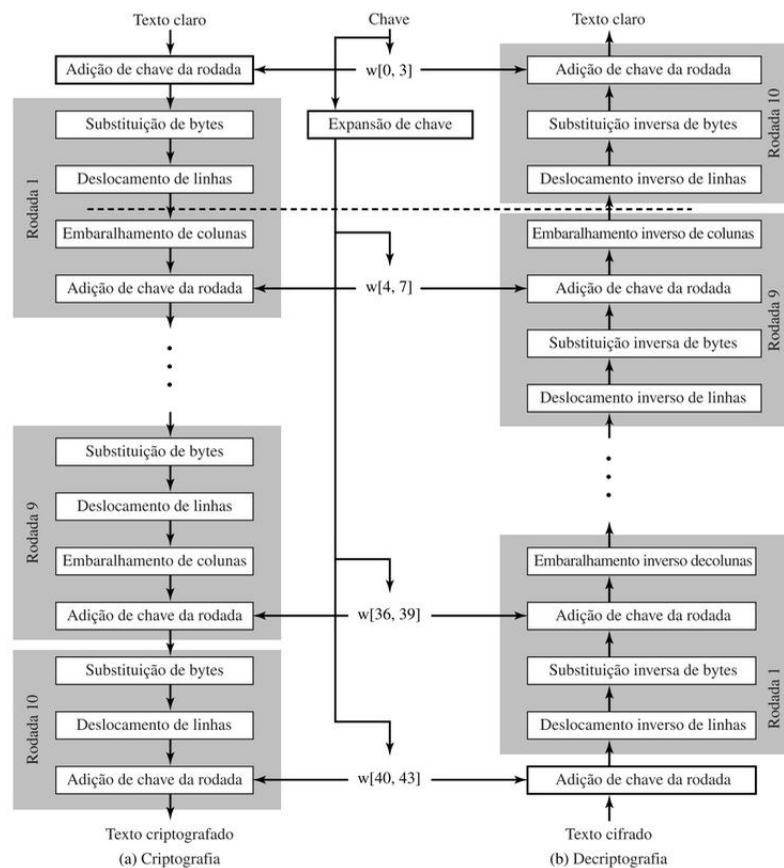


Figura 09 – Funcionamento do AES.

Fonte: Forouzan, Mosharraf, 2013.

Algoritmos de Chave Assimétrica (ou Pública)

A criptografia de chave assimétrica utiliza duas chaves distintas: uma chave pública (que pode ser de conhecimento de qualquer pessoa) e uma chave privada (que é do conhecimento somente de quem possui a chave). O

algoritmo é implementado de tal forma que se o texto for cifrado com a chave privada, somente a chave pública pode fazer a decifração do texto. Se o texto for cifrado com a chave pública, somente a chave privada pode fazer a decifração.

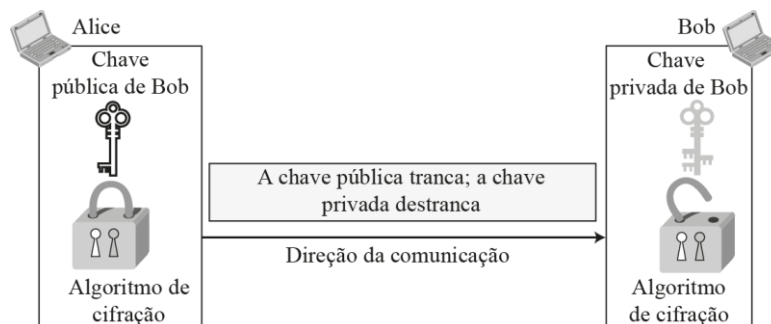


Figura 10 – Algoritmos de Chave Assimétrica.

Fonte: Forouzan, Mosharraf, 2013.

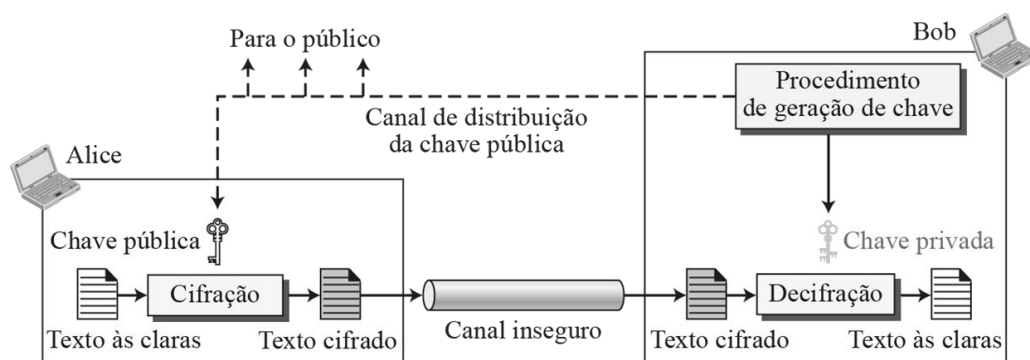


Figura 11 – Algoritmos de Chave Assimétrica.

Fonte: Forouzan, Mosharraf, 2013.

Esse método de criptografia foi proposto pela primeira vez em 1976 por Diffie e Hellman.

O Algoritmo RSA

O RSA, nomeado em função dos nomes de seus inventores (Rivest, Shamir e Adleman), surgiu em 1978 e desde aquela época prevalece como o único método amplamente aceito e implementado de criptografia de chave pública. O RSA sobreviveu a todas as tentativas de rompimento por mais de 25 anos e é considerado um algoritmo forte. Grande parte da segurança prática se baseia

nele. Sua principal desvantagem é exigir um tamanho de chave de no mínimo 1024 bits para manter um bom nível de segurança e isso o torna muito lento. O RSA se baseia em alguns princípios da teoria dos números primos. As chaves públicas e privadas são uma função de dois números primos e uma chave não pode ser obtida através da outra. A segurança do algoritmo se baseia na dificuldade de fatorar números extensos. Para fatorar, por exemplo, um número de 500 dígitos usando um sistema computacional é necessário 10^{25} anos, usando a força bruta. Quando essa fatoração se tornar viável daqui a alguns anos, basta escolher uma chave maior (2048 bits, por exemplo) (Tanenbaum, 2011).

Texto simples (P)		Texto cifrado (C)			Após a decodificação	
Simbólico	Numérico	P^3	$P^3 \pmod{33}$	C^7	$C^7 \pmod{33}$	Simbólico
S	19	6859	28	13492928512	19	S
U	21	9261	21	1801088541	21	U
Z	26	17576	20	1280000000	26	Z
A	01	1	1	1	01	A
N	14	2744	5	78125	14	N
N	14	2744	5	78125	14	N
E	05	125	26	8031810176	05	E
Cálculo do transmissor				Cálculo do receptor		

Figura 12 – Funcionamento do RSA.

Fonte: Tanenbaum, 2011.

Sumários de mensagens – Message Digests.

O Sumário de mensagens se baseia na ideia de uma função de hash unidirecional que extrai um trecho qualquer do texto simples e calcula uma sequência de bits de tamanho fixo. Calcular um sumário de mensagens a partir de um texto simples é muito mais rápido que criptografar esse texto simples com um algoritmo de chave pública. O sumário de mensagens com uma função de hash é utilizado para determinar se a informação foi alterada já que a alteração de um único bit da informação produz um hash completamente diferente;

MD5 (message Digest).

O MD5 é o quinto de uma série de sumários de mensagens projetados por Ronald Rivest (do RSA). Ele usa uma tabela criada a partir da função matemática seno para obter maior precisão nos cálculos. Apesar de ainda ser

utilizado, ele possui alguns pontos fracos que possibilitam que existam dois sumários iguais para textos diferentes.

SHA-1(Secure Hash Algorithm).

O SHA-1 opera tratando os bits de uma maneira suficientemente complicada, de modo que cada bit da saída seja afetado por cada bit da entrada. Ele processa os dados de entrada em blocos de 512 bits e gera um sumário da mensagem de 160 bits.

Obtendo funções de segurança com os algoritmos de criptografia e o sumário de mensagens.

Sigilo ou Confidencialidade.

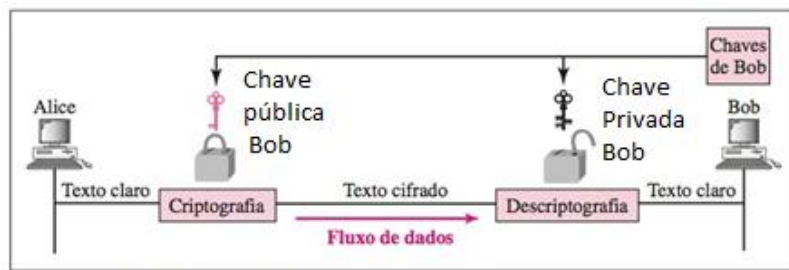
Podemos obter o sigilo utilizando chaves simétricas, uma vez que somente quem possui as chaves podem ter acesso ao texto claro.



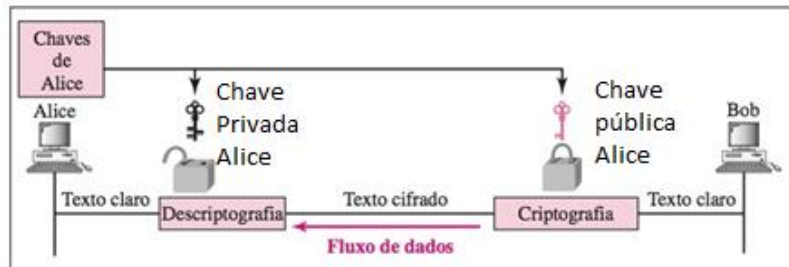
Figura 13 – Sigilo com Chaves Simétricas.

Fonte: Forouzan, 2008.

O sigilo também é obtido utilizando chaves assimétricas quando Alice envia para Bob um texto cifrado com a chave pública de Bob. Somente a chave privada de Bob conseguirá decifrar a mensagem e ter acesso ao texto claro. O mesmo ocorre quando Bob quer enviar uma mensagem sigilosa para Alice. Ele cifra o texto com a chave pública de Alice e somente a chave privada de Alice consegue decifrar a mensagem.



a. As chaves de Bob são usadas na comunicação Alice-Bob



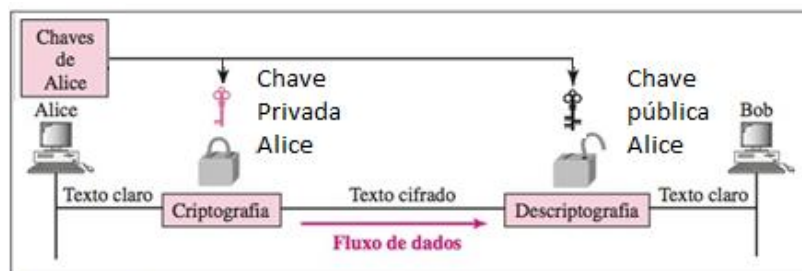
b. As chaves de Alice são usadas na comunicação Bob-Alice

Figura 14 – Sigilo com Chaves Assimétricas.

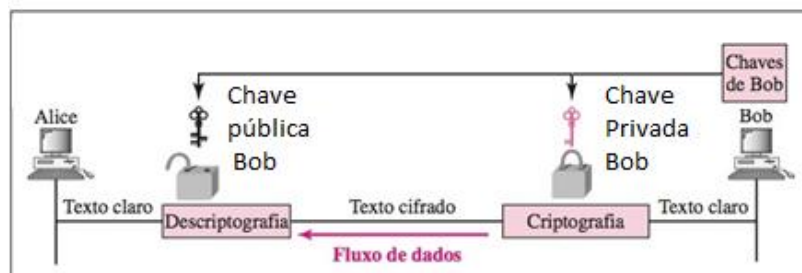
Fonte: Forouzan, 2008.

Autenticação.

Na autenticação utilizando chaves assimétricas, Alice envia um texto cifrado utilizando a sua chave privada. Bob somente conseguirá decifrar a mensagem criptografada utilizando a chave pública de Alice. Bob terá certeza que quem enviou a mensagem foi Alice. Bob para se autenticar perante Alice, precisa enviar uma mensagem cifrada com a sua chave privada. Alice somente conseguirá decifrar a mensagem utilizando a chave pública de Bob. Alice terá a certeza de que foi Bob quem enviou a mensagem.



a. As chaves de Alice são usadas na comunicação Bob-Alice



b. As chaves de Bob são usadas na comunicação Alice-Bob

Figura 15 – Autenticação com Chaves Assimétricas.

Fonte: Forouzan, 2008.

Não repúdio ou Irretratabilidade.

A irretratabilidade é obtida utilizando chaves assimétricas e uma entidade central confiável. Alice cifra uma mensagem com a chave privada dele e essa mensagem possui como destino Bob. Entretanto, ela solicita à uma entidade terceira confiável para fazer a entrega da mensagem. A entidade terceira confiável decifra a mensagem com a chave pública de Alice autenticando-a. Em seguida, a entidade cifra a mensagem com a chave privada da entidade terceira confiável e a envia à Bob. Bob decifra a mensagem com a chave pública da entidade terceira confiável. Não há como Alice negar ou refutar a mensagem, uma vez que foi autenticada pela entidade terceira que mantém cópias das mensagens armazenadas.

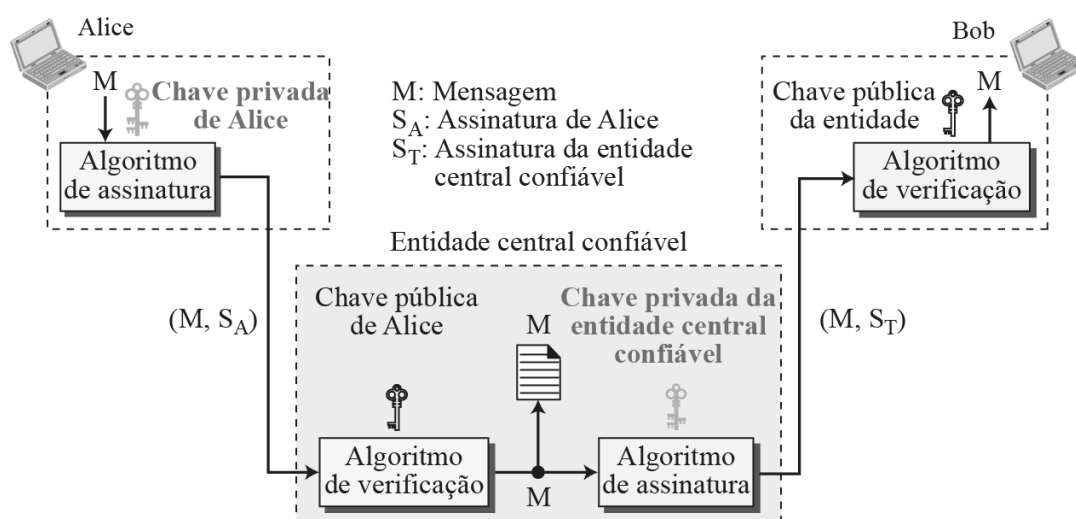


Figura 16 – Irretratabilidade com Chaves Assimétricas.

Fonte: Forouzan, Mosharraf, 2013.

Integridade.

A integridade é obtida com uma função de hash. Calcula-se o hash de um documento. Esse hash é criptografado com a chave pública de Bob. Alice envia o documento em texto claro e o hash criptografado. Bob recebe os dois e aplica a mesma função de hash no documento. Se o resultado for o mesmo do hash criptografado ao qual somente Bob terá acesso com a sua chave privada, ele saberá que o documento manteve a integridade durante a transmissão.

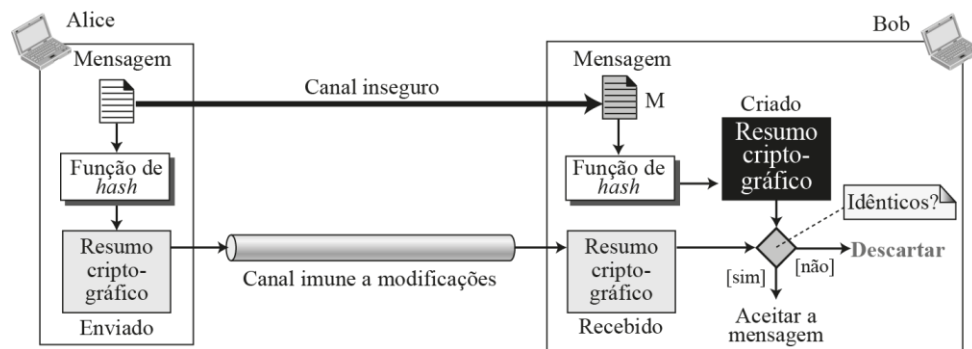


Figura 17 – Integridade.

Fonte: Forouzan, Mosharraf, 2013.

Assinatura Digital

Assinatura Digital é feita de forma parecida com a integridade. Utiliza-se uma função de hash e criptografia. Alice calcula o hash e o criptografa com a sua chave privada. Somente a chave pública de Alice consegue decifrar a mensagem e obter o hash.

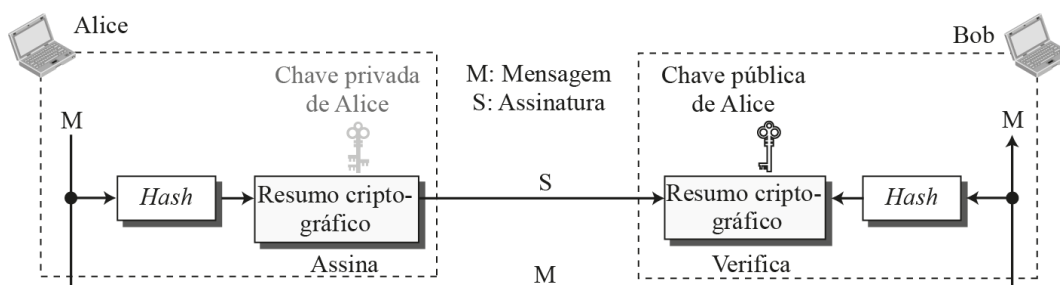


Figura 18 – Assinatura Digital.

Fonte: Forouzan, Mosharraf, 2013.

Certificado Digital.

Vimos anteriormente que as criptografias de chaves simétricas e assimétricas nos permitem conseguir autenticação, sigilo e integridade. A grande questão diz respeito à troca de chaves simétricas ou a divulgação da chave pública, uma vez que uma pessoa mal intencionada pode se fazer passar por outra divulgando chaves públicas falsas. A maneira que foi encontrada para autenticar as chaves públicas foi a criação de Certificados Digitais emitidos por uma Autoridade Certificadora (AC). Uma AC é uma organização estadual ou federal que vincula uma chave pública a uma entidade e emite um certificado. A AC em si tem uma chave pública bem conhecida que não pode ser forjada. A AC verifica a identidade de uma empresa (usando documentos jurídicos). Ela

pede a chave pública da empresa e a insere em um certificado. Para evitar que o próprio certificado seja forjado, a AC assina o certificado com sua chave privada. A empresa pode distribuir o certificado assinado. Quem quiser saber a chave pública da empresa obtém o certificado assinado e usa a chave pública da AC para extrair a chave pública da empresa (Forouzan, 2013).

Exemplo de um certificado:

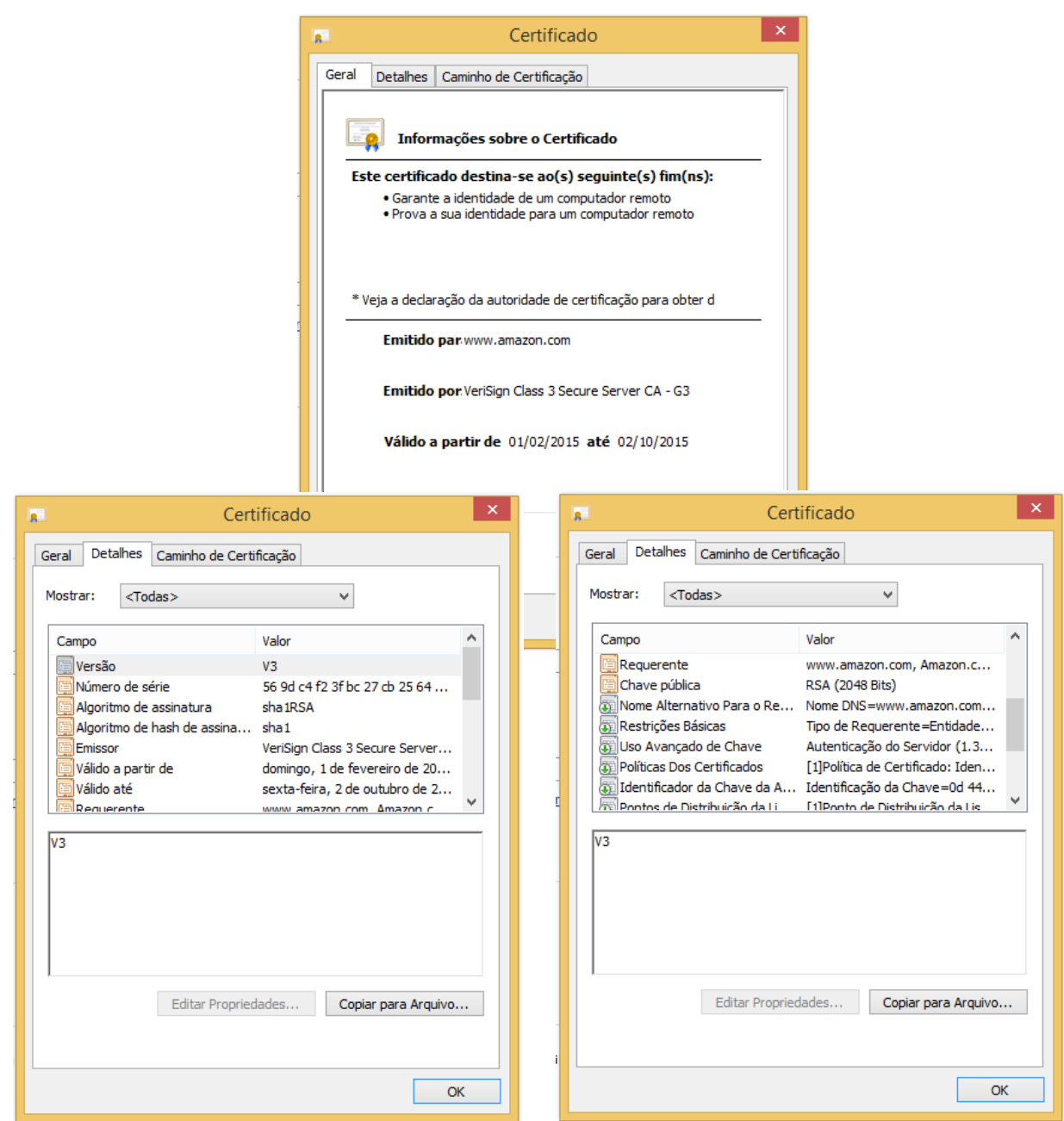


Figura 19 – Certificado Digital de www.amazon.com.

SSL – Secure Socket Layer e HTTPS.

O SSL é um padrão de segurança, criado pela Netscape, para se criar uma conexão segura entre um servidor WEB e um navegador. O SSL cria um link criptografado para garantir integridade e privacidade. O servidor WEB deve possuir um certificado fornecido por uma Autoridade Certificadora (CA) (Tanenbaum, 2011).

O SSL inclui:

- Negociação de parâmetros entre cliente e servidor;
- Autenticação mútua de cliente e servidor;
- Comunicação secreta;
- Proteção da integridade dos dados.
- Quando o HTTP é usado sobre SSL, ele é denominado HTTPS (Secure HTTP).

Localização do SSL no modelo de camadas.



Figura 20 – Localização do SSL nas Camadas.

Fonte: Forouzan, Mosharraf, 2013.

Segundo Forouzan (2008), quando um cliente faz compras on-line, espera-se que tenha os seguintes serviços de segurança:

1. O cliente precisa estar seguro de que o servidor pertence ao verdadeiro fornecedor e não a um impostor. O cliente não quer dar a um impostor o número de seu cartão de crédito (autenticação de entidades). Da mesma forma, o fornecedor precisa autenticar o cliente.

2. O cliente e o fornecedor precisam ter a certeza de que o conteúdo da mensagem não é modificado durante a transição (integridade de mensagem).
3. O cliente e o fornecedor precisam ter certeza de que um impostor não intercepte informações confidenciais, como um número de cartão de crédito (confidencialidade).

O SSL define quatro protocolos em duas camadas.

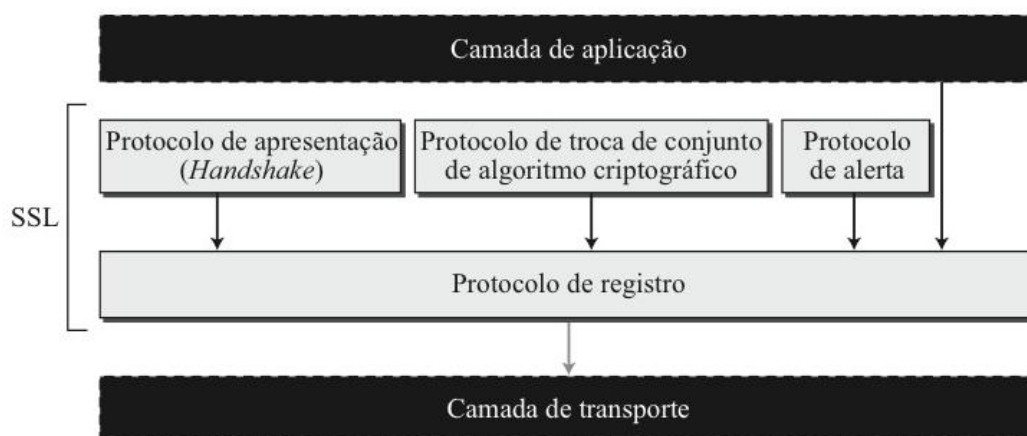


Figura 21 – Protocolos do SSL.

Fonte: Forouzan, Mosharraf, 2013.

O **Protocolo de Registro** atua como transportador. Ele transporta mensagens provenientes dos três outros protocolos, bem como os dados provenientes da camada de aplicação.

O **Protocolo de Apresentação** estabelece um conjunto de algoritmos e fornece as chaves e parâmetros de segurança correspondentes. Ele também autentica o servidor em relação ao cliente e o cliente em relação ao servidor, se necessário.

O **Protocolo de Troca de Conjunto de Algoritmos Criptográficos** é usado para sinalizar se os segredos criptográficos estão prontos.

O **Protocolo de Alerta** é usado para reportar condições anormais.

Vale detalhar o **Protocolo de Apresentação**. Ele usa mensagens para negociar o conjunto de algoritmos criptográficos, para autenticar o servidor em relação ao cliente e o cliente em relação ao servidor, se necessário, bem como para trocar informações usadas na construção dos segredos criptográficos. A apresentação é feita em quatro fases (Forouzan, 2013).

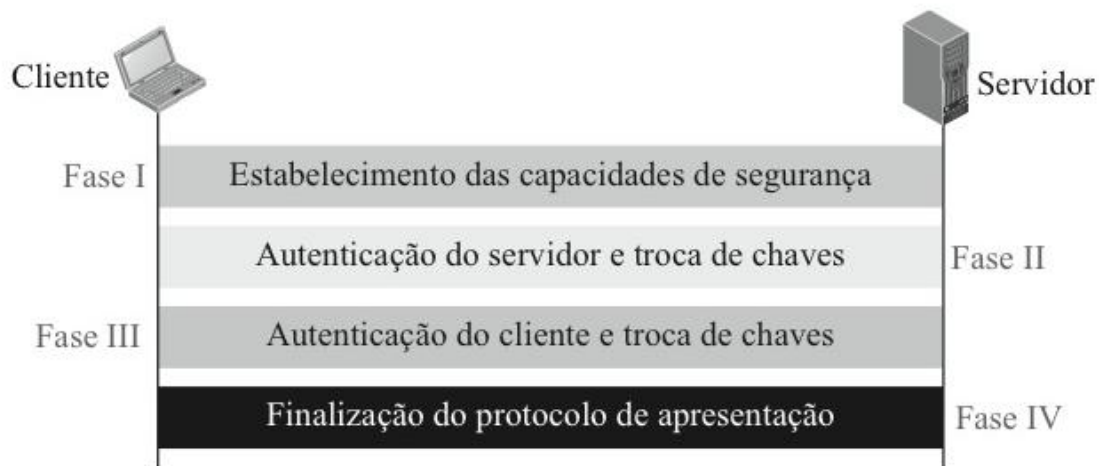


Figura 22 – Protocolo de Apresentação do SSL.

Fonte: Forouzan, Mosharraf, 2013.

Fase I: Estabelecimento das capacidades de segurança

Na Fase I, o cliente e o servidor anunciam suas capacidades de segurança (os algoritmos suportados por eles) e escolhem aqueles que sejam convenientes para ambos. Nessa fase, o identificador da sessão é estabelecido e o conjunto de algoritmos criptográficos é escolhido. As partes concordam com um método de compressão em particular. Finalmente, dois números aleatórios são gerados, um pelo cliente e outro pelo servidor, para serem usados na criação de um segredo mestre, como vimos anteriormente. Depois da Fase I, o cliente e o servidor sabem a versão do SSL, os algoritmos de criptografia, o método de compressão e os dois números aleatórios para a geração de chaves.

Fase II: Autenticação do servidor e troca de chaves

Na Fase II, o servidor se autentica, se necessário. O servidor pode enviar o seu certificado, sua chave pública, e também pode solicitar certificados do cliente. Depois da Fase II, o servidor encontra-se autenticado em relação ao cliente, e o cliente sabe a chave pública do servidor, se necessário.

Fase III: Autenticação do cliente e troca de chaves

A Fase III foi concebida para autenticar o cliente. Depois da Fase III, o cliente encontra-se autenticado em relação ao servidor e tanto o cliente como o servidor conhecem o segredo pré-mestre.

Fase IV: Finalização e encerramento

Na Fase IV, o cliente e o servidor enviam mensagens para alterar os algoritmos criptográficos especificados e para finalizar o Protocolo de Apresentação.

SSL 3.0 – Exemplo de Uso

Um usuário acessa o site **www.pucminas.br**. Em um ponto específico, o site Web insere uma camada adicional SSL (Tanenbaum, 2011)

O navegador do usuário solicita uma conexão ao servidor **www.pucminas.br**. Essa solicitação de conexão contém a versão SSL, preferencias dos algoritmos de compactação e criptografia disponíveis no browser e um nonce RA. Um nonce é um número aleatório que será utilizado apenas uma vez pelo protocolo.

O servidor **www.pucminas.br** escolhe entre os algoritmos disponíveis no navegador Web do usuário e envia o seu próprio nonce RB.

Em seguida o servidor **www.pucminas.br** envia um certificado contendo sua chave pública e sua assinatura.

Todos os navegadores, inclusive o do usuário, são pré-carregados com vários certificados de Autoridades Certificadoras.

O servidor **www.pucminas.br** solicita que o navegador do usuário envie os seus dados.

O navegador Web do usuário escolhe uma chave pré-mestre aleatória de 384 bits, a criptografa utilizando RSA e com a chave pública do servidor www.pucminas.br e envia o resultado para ele.

A chave de sessão real usada para codificar os dados é derivada da chave pré-mestre combinada com ambos os nonces (R_A e R_B) e tanto o navegador quanto o servidor sabem como derivá-lo.

O navegador muda o algoritmo e informa ao Servidor www.pucminas.br.

O Servidor confirma a mudança do algoritmo.

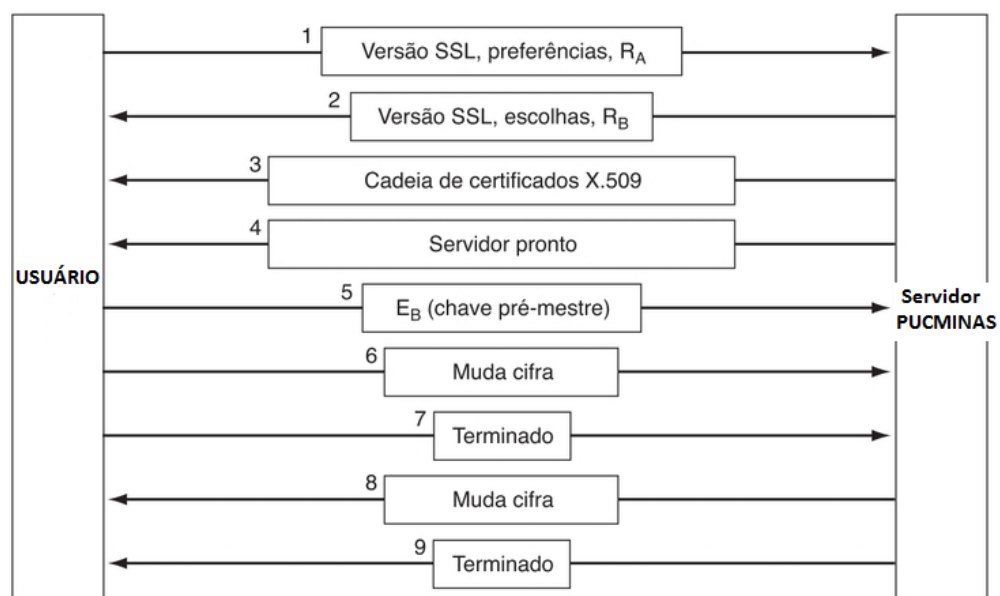


Figura 23 – Funcionamento do SSL.

Fonte: Tanenbaum, 2011.

O navegador tem certeza de que está trocando dados com www.pucminas.br, pois usou o certificado dele para autenticação. No entanto www.pucminas.br não pode autenticar o usuário do navegador, pois é pouco provável que usuários comuns possuam certificados digitais.

Assim, é bem possível que a primeira mensagem que www.pucminas.br solicite do usuário do navegador, seja uma autenticação de *login* e senha, que não

pertence à especificação SSL, mas que pode autenticar o usuário no serviço de diretórios pucminas.br.

O SSL admite vários algoritmos de criptografia. O mais forte usa o DES triplo com três chaves separadas para criptografia e com o SHA-1. Essa combinação é lenta e por isso é utilizada em transações bancárias. Para aplicações comuns de comércio eletrônico é utilizado o RC4 com uma chave de 128 bits para criptografia e o MD5 para autenticação de mensagens.

Métodos de Autenticação.

Segundo Forouzan (2011), a autenticação de entidades é uma técnica desenvolvida para possibilitar que uma parte prove a identidade de outra. Essa entidade pode ser uma pessoa, um processo, um cliente ou um servidor. A entidade que precisa provar a identidade é chamada de requerente. A entidade que tenta provar a identidade do requerente é o verificador. Ao contrário da autenticação de mensagens, a autenticação de entidades precisa ser em tempo real.

Uso de Senhas

O método de autenticação de entidades mais simples e mais antigo é a senha. A senha é usada quando o usuário precisar acessar e usar os recursos de um sistema (login). Cada usuário tem uma identificação (pública) e uma senha, (privada).

Uma senha é usada repetidas vezes para cada acesso. Com isso, ela está sujeita a vários tipos de ataque.

Ataque de escuta. Quando alguém observa o usuário digitar sua senha ou quando usa um software de captura de pacotes que pode mostrar senhas não criptografadas.

Ataque de roubo de senha. Quando a senha que está escrita em papel é roubada por um terceiro.

Ataque de Adivinhação. Quando alguém tenta diversas combinações de caracteres para descobrir a senha de outra pessoa.

Uso de Desafio-Resposta

No desafio-resposta, o requerente prova que conhece um segredo sem revelá-lo, ou seja, o requerente não revela o segredo ao verificador. O verificador o possui ou o descobre. O desafio é um valor que varia com o tempo, como um número aleatório, um registro de horas, ou uma função matemática irreversível que é enviado pelo verificador. O requerente resolve o desafio e envia o resultado, denominado resposta, ao verificador. Uma resposta certa mostra que o requerente conhece o segredo.

FIREWALL

Um Firewall é um (conjunto de) componente(s) que protege(m) a rede local contra ataques provenientes de redes externas interligadas (Internet e outras), enquanto proporciona o acesso a estas redes. É um separador, limitador e analisador do tráfego entre a rede local e suas redes interligadas. Ele bloqueia qualquer tipo de acesso que não passe pelo Firewall e estabelece uma política de segurança que defina tráfego autorizado. Sua instalação deve ser feita com um sistema operacional seguro e confiável.

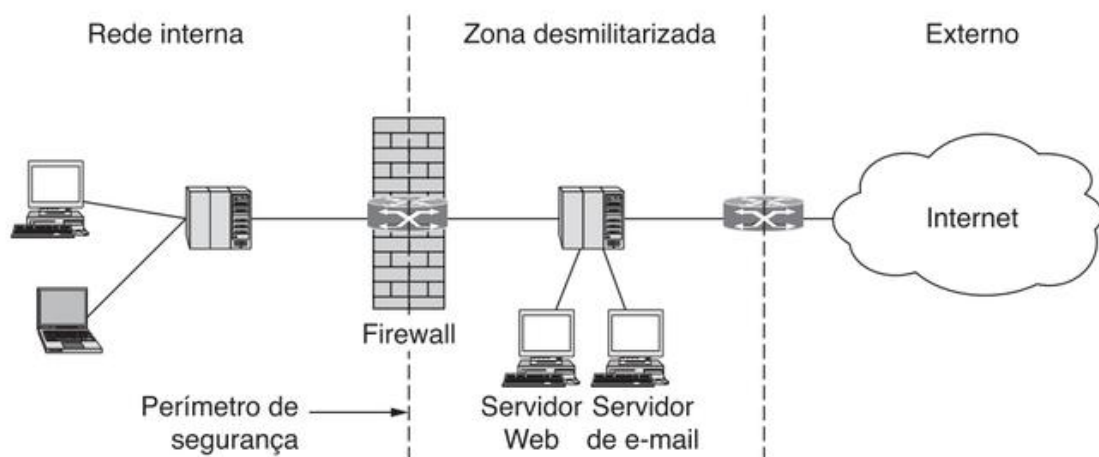


Figura 25 – Rede com Firewall.

Fonte: Tanenbaum, 2011.

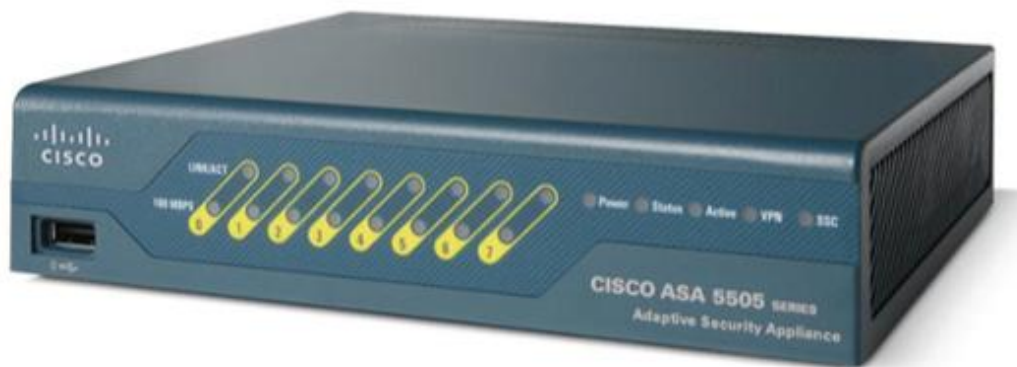


Figura 26 – Firewall Cisco ASA 5505.

Fonte: Cisco.com, 2025.

Os Firewalls podem funcionar como um filtro de pacote ou um gateway de aplicação.

Filtro de pacotes

Quando funciona como um filtro de pacotes, o Firewall faz um roteamento seletivo de pacotes entre a rede local e a rede externa. Ele utiliza um conjunto de regras que atuam sobre os cabeçalhos dos pacotes IP e segmentos TCP para selecionar os pacotes. Essas regras são aplicadas em cada pacote, na direção desejada, entrada ou saída para que seja tomada uma decisão, encaminhar ou descartar o pacote. Essas regras são estabelecidas utilizando as seguintes informações, disponíveis:

- Endereços IP de origem e de destino.
- Tipo de Protocolo (TCP, UDP ou ICMP).
- Portas (TCP ou UDP) de origem e de destino.
- Tipo de mensagem ICMP.
- Interfaces de entrada e de saída dos pacotes.

As vantagens de um filtro de pacotes São:

- Ele é transparente para o usuário.
- Faz o processamento dos pacotes em alta velocidade.

As desvantagens de um filtro de pacotes são:

- Dificuldade para configurar as regras de filtragem.
- Inexistência de autenticação.

A figura 27 ilustra as regras de um filtro de pacotes usando o IPTABLES.

```
# The default for FORWARD is DROP
#
#echo "    clearing any existing rules and setting default policy.."
$IPTABLES -F INPUT ACCEPT
$IPTABLES -F INPUT
$IPTABLES -F OUTPUT ACCEPT
$IPTABLES -F OUTPUT
$IPTABLES -F FORWARD DROP
$IPTABLES -F FORWARD
$IPTABLES -t nat -F

#echo "    FWD: Allow all connections OUT and only existing and related ones IN"
#echo "    FWD: Permite saída da rede Acadêmica"
#$IPTABLES -A FORWARD -d 0.0.0.0/0 -s 190.10.0.0/16 -m state --state ESTABLISHED,RELATED -j ACCEPT
$IPTABLES -A FORWARD -i $EXTIF -o $INTIF2 -m state --state ESTABLISHED,RELATED -j ACCEPT
$IPTABLES -A FORWARD -p udp -s 190.10.0.0/16 -d 0.0.0.0/0 -j ACCEPT
$IPTABLES -A FORWARD -p icmp -s 190.10.0.0/16 -d 0.0.0.0/0 -j ACCEPT
$IPTABLES -A FORWARD -p tcp -s 190.10.0.0/16 -d 0.0.0.0/0 -j ACCEPT
```

Figura 27 – Regras do IPTABLES.

Gateway de Aplicação

Quando funciona como um Gateway de aplicação, o Firewall opera na camada de aplicação. Ele recebe as requisições de serviços dos usuários e encaminha (ou não) para os respectivos serviços na rede externa, de acordo com uma política de segurança estabelecida. Este sistema atua de forma transparente, como um controlador de tráfego entre os usuários internos e os serviços externos, na camada de aplicação. Dado a forma como trabalha, é também denominado **Servidor Proxy**.

Vantagens

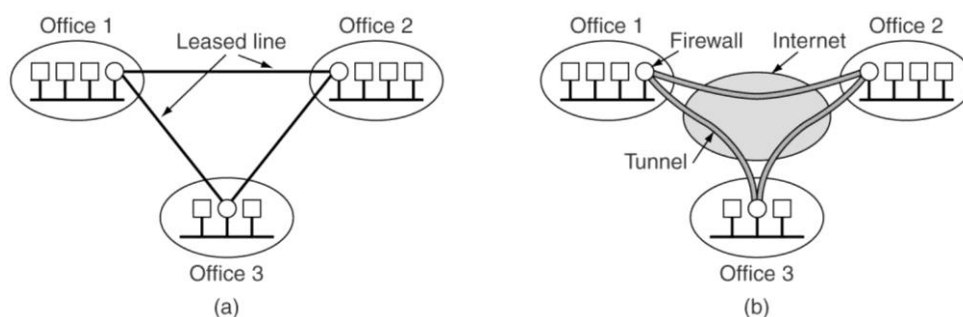
- Oferece maior segurança que os filtros de pacotes pois autentica o usuário.
- Precisa examinar apenas algumas poucas aplicações permitidas.
- Facilidade de auditar e registrar todo tráfego de entrada.

Desvantagens

- Sobrecarga de processamento adicional em cada conexão.

VPN – Virtual Private Network.

Uma VPN é uma rede com uma conexão segura baseada em criptografia entre dois pontos distintos que funciona através de uma rede pública. O objetivo é transportar informação sensível através de uma rede insegura (como por exemplo, a Internet. As VPNs são utilizadas para interligar pontos distantes através da Internet (matriz e filial, fornecedor e cliente, empresa e funcionário, etc)



Rede privada de linha dedicada.

Uma rede privada virtual – VPN.

Figura 28 – VPN – Rede Privada Virtual.

Fonte: Tanenbaum, 2011.

As VPNs estabelecem circuitos virtuais entre os pontos de conexão, utilizando um método denominado tunelamento (tunneling) que juntamente com a criptografia garante a privacidade dos dados transmitidos através da rede pública. Ele pode ser implementado pelo cliente ou pelo próprio provedor de Internet se este provedor ou o cliente possuírem os equipamentos adequados. Um túnel é uma configuração que identifica os endereços IPs de cada extremidade da conexão e fornece algum mecanismo adicional de autenticação e/ou assinatura digital.

Requisitos Básicos de uma VPN

- Autenticar o usuário e permitir o acesso apenas de usuários autorizados.
- Auditar qualquer tentativa de acesso, autorizado ou não.
- Gerenciamento de Endereços com a não divulgação dos endereços internos da rede, utilizando endereços externos fictícios.

- Criptografia de Dados para Manter a privacidade dos dados na rede pública.

A seguir são apresentados alguns itens que são muito importantes na segurança de Servidores Web, ou qualquer outro servidor da rede.

Segurança Física de Servidores Web.

Controle de Ativos.

Os servidores devem fazer parte de um conjunto de equipamentos catalogados e inventariados. Deve-se ter registrado a configuração de cada item de hardware que o compõe. Isso facilita a assistência técnica dos equipamentos e o seu controle.

Redundância de equipamentos.

Todo servidor precisa ter um hardware de redundância, pois caso ele venha a sofrer uma pane, os serviços podem ser reativados em um curto espaço de tempo. É sugerido também que, caso seja possível, se utilize cluster de balanceamento de carga.

Redundância de alimentação elétrica.

Deve-se também estar atento às questões de interrupção de energia elétrica e caso seja possível, recomenda-se a utilização de geradores em caso de uma interrupção elétrica muito prolongada.

Nobreak.

Os nobreaks além de possuírem filtros para a energia elétrica podem segurar o funcionamento do servidor durante um curto período de tempo. Isso evita um desligamento desnecessário e que pode corromper o sistema operacional ou danificar o disco rígido.

Climatização e iluminação.

Os servidores devem estar localizados em um local de boa iluminação e com climatização adequada.

Controle de Acesso.

Os servidores devem estar localizados em um local com controle de acesso e somente pessoas autorizadas devem ter acesso a eles. O acesso

aos servidores também deve ser monitorado com o controle via CFTV ou com o registro de acesso físico.

Proteção contra incêndio.

A maioria dos Datacenter que hospedam servidores de clientes ou da própria empresa possuem modernos sistemas de proteção contra incêndio. É muito importante levar em consideração esses sistemas.

Segurança Lógica dos Servidores Web (CERT.br, 2025).

Estratégias de Particionamento.

Utilize partições diferentes no servidor. O sistema operacional deve estar localizado em uma partição e as demais aplicações devem estar localizadas em outra partição. Isso evita que algum software mal intencionado trave o servidor ao encher a partição do banco de dados por exemplo.

Documentação da Instalação e Configuração.

Sempre tenha atualizado um roteiro passo a passo da instalação e da configuração dos servidores (No estilo dos tutoriais da disciplina). Isso faz com que se possa reinstalar um servidor que sofreu pane à partir do início.

Senhas de Administrador.

Crie senhas de root e de administrador que possuam uma combinação de letras minúsculas, maiúsculas, números e caracteres especiais. Evite usar datas ou senhas óbvias. Essas senhas também devem ser trocadas periodicamente.

Instalação Mínima.

Instale apenas o mínimo necessário ao funcionamento do servidor. Muitas aplicações desnecessárias acabam deixando brechas que podem ser exploradas por alguém mal intencionado.

Desativação de Serviços não Utilizados.

Desative qualquer aplicação que realmente não for utilizada. A justificativa é a mesma do item anterior.

Instalação de Correções.

Sempre esteja atendo às correções do sistema operacional, do servidor Web, do banco de dados e de qualquer aplicação adicional que faça parte

do seu sistema. Software desatualizado é um prato cheio para pessoas que exploram vulnerabilidades de servidores.

Prevenção de Abuso de Recursos.

Esteja sempre atento para que nenhum usuário abuse dos recursos da rede desnecessariamente. Esses recursos envolvem memória, espaço em disco, largura de banda, etc.

Controle de Acesso a Proxies Web.

Ao instalar o seu servidor proxy, configure também o controle de acesso. Isso faz com que tudo que os usuários acessam via Web fique registrado no servidor. O que facilita uma auditoria.

Educação dos Usuários.

Realize treinamentos periódicos com os usuários. A cartilha da segurança da informação do CERT.br deve ser leitura obrigatória para todos. Um treinamento adequado evita que um usuário execute alguma aplicação não homologada pela equipe de suporte em sua estação de trabalho, por exemplo.

Sincronização de Relógios.

Muitos protocolos utilizam a hora para algum tipo de operação. Fazer com que todos os computadores de uma rede funcionem sincronizados com um servidor de hora melhora a segurança. Isso também é muito importante para a geração de Logs de registros de atividades da rede ou do servidor.

Timezone.

É muito importante também a configuração correta da Timezone dos computadores. A justificativa é a mesma para o item anterior.

Comunicação Eficiente.

Manter uma comunicação eficiente entre os profissionais envolvidos com a administração dos servidores Web é fundamental. Isso evita perda de tempo e diminui o tempo de parada dos servidores. Também é importante ter os contatos de e-mail e telefone de todos os responsáveis, desde o analista de desenvolvimento até os técnicos de manutenção.

Controle de Alterações na Configuração.

Mantenha sempre um relatório de todas as alterações de software e hardware efetuadas no servidor Web.

Uso de Contas Privilegiadas.

Evite acessar o servidor remotamente com contas de superusuário ou administrativas. A recomendação é o acesso via usuário normal e uma vez conectado ao servidor pode-se executar programas ou realizar tarefas com permissões administrativas (o que foi feito no acesso ao Linux Debian).

Logs.

Os logs devem sempre estar ativados, pois são uma importante ferramenta para se descobrir qualquer problema ou falha de segurança no servidor.

Políticas de Backup e Restauração de Sistemas.

Desenvolva uma política de backup e restauração de sistemas. Você deve possuir mídias de backup tanto na empresa quanto em algum outro local seguro.

Uso Eficaz de Firewalls

Sempre proteja a sua rede com firewalls. A utilização de firewalls com software livre ou um ASA da Cisco é de fundamental importância para se evitar ataques provenientes da Internet à sua rede local ou aos seus servidores.

Uma medida de segurança muito importante na operação de redes é a substituição de protocolos onde não há autenticação através de senhas, ou onde as senhas trafeguem em claro, por outros que corrijam estas deficiências. A lista de protocolos cuja utilização deve ser evitada na medida do possível inclui:

- Telnet;
- FTP;
- POP3;
- IMAP;
- rlogin;
- rsh;
- rexec.

A maioria dos protocolos citados pode ser substituída pelo SSH. Essa substituição faz com que o tráfego entre cliente e servidor passe a ser criptografado.

Dicas adicionais de segurança para servidores e redes de computadores (MCCLURE, 2014):

Senhas fracas

Senhas fracas, facilmente adivinháveis e reutilizadas podem arruinar sua segurança. Contas de teste tem senhas ruins e pouco monitoramento. Não reutilize senhas em seus sistemas nem em sites da Internet.

Software sem patch

Software sem patch, desatualizado, vulnerável ou deixado com as configurações padrão. A maioria das brechas pode ser evitada com a aplicação de patches assim que for possível e eles sejam testados.

Pontos de acesso remoto inseguros.

Pontos de acesso remoto inseguros e não monitorados oferecem uma das maneiras mais fáceis de acessar sua rede corporativa. Um dos pontos nevrálgicos são contas de ex-funcionários que não foram desabilitadas.

Vazamento de informações.

O vazamento de informações pode fornecer ao invasor dados sobre versões do sistema operacional e de aplicativos, usuários, grupos, compartilhamentos e DNS. O uso de ferramentas como Google, Facebook, Linked-In, e ferramentas inclusas no Windows pode fornecer muitas informações para qualquer invasor.

Hosts executando serviços desnecessários.

Hosts executando serviços desnecessários, como FTP, DNS, RPC e outros, oferecem uma área de superfície de ataque muito maior para os invasores explorarem.

Firewalls mal configurados.

As regras de firewall podem se tornar tão complexas que frequentemente entram em conflito. Muitas vezes, regras de firewall de teste são inseridas ou correções de emergência são aplicadas sem serem removidas posteriormente. Regras de firewall podem permitir que invasores acessem DMZs ou redes internas.

Servidores de Internet mal configurados.

Servidores de Internet mal configurados, especialmente servidores web com vulnerabilidades de script entre sites e injeção de SQL, podem debilitar completamente toda sua segurança.

Login inadequado.

Invasores podem fazer o que quiserem em seu ambiente, em razão de um monitoramento inadequado do gateway de Internet e também do host. Pense na possibilidade de monitorar também o tráfego de saída para ajudar na detecção de adversários avançados e persistentes em sua rede.

Controles de arquivos e diretórios excessivos.

Os compartilhamentos de arquivos internos do Windows e do UNIX que tem pouco ou nenhum controle de acesso podem permitir que um invasor se mova livremente em sua rede e leve ao vazamento de sua propriedade intelectual mais confidencial.

Falta de políticas de segurança documentadas.

Controles de segurança casuais e não documentados permitem que padrões de segurança inconsistentes sejam aplicados em seus sistemas ou redes, o que inevitavelmente leva a comprometimentos de sistema.

Referências.

CERT.BR. **Segurança de Redes de Computadores.** Disponível em <http://www.cert.br/docs/seg-adm-redes/seg-adm-redes.pdf>. Acesso 25 fev. 2025.

FOROUZAN, Behrouz A. **Comunicação de dados e redes de computadores.** 4. Porto Alegre ArtMed 208

FOROUZAN, Behrouz A. **Redes de computadores uma abordagem top-down.** 1. Porto Alegre AMGH 2013.

MCCLURE, Stuart. **Hackers expostos segredos e soluções para a segurança de redes.** Porto Alegre Bookman 2014.

TANENBAUM, Andrew S.; Wetheral, David. **Redes de Computadores - 5ª edição.** Pearson. 2011.